
Access Control Policy

Policy

PREPARED FOR
Northwind Financial Services Ltd

REFERENCE
POL-AC-001

DOCUMENT TYPE
Policy

VERSION
v2.0

DOCUMENT OWNER
Head of Information Security

APPROVER
Chief Information Security
Officer

EFFECTIVE DATE
2026-02-01

REVIEW CYCLE
12 months

NEXT REVIEW
2027-02-01

FRAMEWORKS
ISO 27001, NIST 800-53

Document Control

Reference	POL-AC-001
Title	Access Control Policy
Document type	Policy
Classification	Confidential
Status	Approved
Document owner	Head of Information Security
Approver	Chief Information Security Officer
Client	Northwind Financial Services Ltd
Frameworks	ISO 27001, NIST 800-53, PCI DSS
Effective date	2026-02-01
Next review	2027-02-01

SUMMARY

This policy establishes the requirements for granting, reviewing and revoking access to Northwind information systems and the cardholder data environment. It applies to all employees, contractors and third parties, and is mandatory for any system that processes, stores or transmits regulated data.

Revision History

Version	Approved	Approved by	Change summary
v2.0	2026-02-01	Chief Information Security Officer	Added quarterly privileged access review and one-business-day revocation requirement.
v1.0	2025-01-15	Chief Information Security Officer	Initial issue.

Contents

Document Control	2
Revision History	2
1 Purpose	4
2 Scope	4
3 Policy Statements	4
4 Roles and Responsibilities	4
5 Management Commitment	5
6 Compliance and Enforcement	5
7 Control Mapping	6
Approval	6

1 Purpose

Unauthorised access is the most frequently exploited weakness in financial services environments, and the majority of material incidents begin with a credential that should have been revoked or was never appropriate to issue. This policy sets the mandatory requirements that limit access to information systems to identified, authorised individuals, and that ensure access is removed promptly when it is no longer justified.

It exists to protect the confidentiality, integrity and availability of Northwind information assets, and to meet the access control obligations placed on the organisation by ISO/IEC 27001:2022, NIST SP 800-53 Revision 5 and the Payment Card Industry Data Security Standard.

2 Scope

This policy applies to all production and pre-production information systems operated by or on behalf of Northwind, including the cardholder data environment, and to every account type used to access them — interactive user accounts, privileged administrative accounts, service accounts and accounts held by third parties.

3 Policy Statements

Access **must** be granted on the principle of least privilege: an account must hold only the permissions required for the role it supports, and no more.

Access **must** be authorised by the system owner before it is provisioned, and the authorisation must be recorded and retained for a minimum of twelve months.

Privileged access **must** be issued separately from an individual's standard account, **must** require multi-factor authentication, and **must** be reviewed at least quarterly by the system owner.

Access **must** be revoked within one business day of a person leaving the organisation or changing to a role that no longer requires it.

4 Roles and Responsibilities

The Chief Information Security Officer owns this policy, approves it, and is accountable for its effectiveness. The Head of Information Security must maintain this policy and report material non-compliance to the Executive Risk Committee. System owners must authorise access to the systems they own and conduct the periodic access reviews required by this policy.

5 Management Commitment

The Executive Risk Committee endorses this policy and commits the resources required to implement and sustain it. Compliance with this policy is a condition of continued access to Northwind systems.

6 Compliance and Enforcement

Compliance is monitored through the periodic access reviews, automated reporting on privileged account usage, and internal audit. Breaches must be reported to the Head of Information Security and are handled under the disciplinary procedure.

7 Control Mapping

This document is mapped to the following catalog controls. Coverage is stated per control: *full* means this document satisfies the control on its own, *partial* means further documents are required, and *supporting* means the text contributes context without satisfying the control.

Control	Name	Coverage	Section
AC - 1	Policy and Procedures	Full	Purpose
AC - 2	Account Management	Full	Policy Statements
AC - 3	Access Enforcement	Full	Policy Statements
AC - 6	Least Privilege	Partial	Policy Statements

Approval

APPROVED BY

Chief Information Security Officer

DOCUMENT OWNER

Head of Information Security

SIGNATURE

DATE

Effective from 2026-02-01.